

Informe CAASM.

La CAASM se está consolidando desde 2025 como el “sistema nervioso central” de la gestión de activos y de la superficie de ataque, y sus indicadores evolucionan claramente hacia: visibilidad unificada, riesgo material, alineamiento regulatorio (NIS2, ENS, GDPR) y capacidad de remediación continua. A nivel España, la presión regulatoria UE-centrada y el peso de sectores esenciales hacen que los indicadores territoriales de CAASM graviten sobre exposición sectorial, criticidad de servicios públicos y madurez de supervisión continua, en sintonía con el enfoque europeo de ENISA y NIS2.¹²³⁴⁵⁶

1. Qué es CAASM hoy (y qué le exigimos)

- La gestión de la superficie de ataque de activos cibernéticos (CAASM) se basa en descubrir, inventariar y correlacionar todos los activos (TI, OT, IoT, nube, identidades, contenedores, APIs) y sus riesgos en un único “panel de realidad” para el equipo de seguridad.⁷²³¹
- Los fabricantes y analistas coinciden en que CAASM ya no es “un inventario más”, sino un agregador de datos que cruza CMDB, EDR, IAM, nubes, vulnerabilidades y telemetría para construir un inventario vivo y accionable de riesgos de superficie de ataque.²⁸³¹⁷
- Desde 2024–2026, los informes de mercado ven a CAASM como pieza clave del giro desde CMDB tradicional hacia gestión de superficie y exposición, con previsión de fuerte despegue del mercado antes de 2027.⁹⁸⁵¹⁰¹¹

Ejemplo ilustrativo: si el ministerio X declara en la CMDB 5.000 servidores, el CAASM le dirá que en realidad expone 5.700 superficies lógicas relevantes (incluyendo VMs olvidadas, microservicios huérfanos y APIs fantasma) y qué parte de esa fauna es verdaderamente peligrosa hoy.⁷⁸⁹¹⁰

1 <https://es-la.tenable.com/cybersecurity-guide/learn/what-is-caasm>

2 <https://www.vectra.ai/topics/attack-surface-management>

3 <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

4 <https://www.marketreportanalytics.com/reports/cyber-asset-attack-surface-management-52485>

5 <https://socradar.io/wp-content/uploads/2025/12/Spain-Threat-Landscape-Report-2025.pdf>

6 <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

7 <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

8 <https://es-la.tenable.com/cybersecurity-guide/learn/what-is-caasm>

9 <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

10 <https://www.vectra.ai/topics/attack-surface-management>

2. Bloques de indicadores CAASM (visión global)

A partir de las definiciones técnicas de proveedores, guías de ASM y análisis sectoriales, las métricas de CAASM en 2025–2026 se agrupan en cinco familias: visibilidad, higiene y control, exposición y riesgo, ciclo de vida de remediación, y alineamiento normativo.¹¹¹²¹³¹⁴¹⁵¹⁶¹⁷

2.1. Visibilidad y cobertura de activos

Indicadores típicos derivados de las capacidades de descubrimiento y agregación descritas por Tenable, CrowdStrike, Zscaler, Vectra y otros:¹⁸¹⁹²⁰²¹²²²³²⁴

11 <https://www.centraleyes.com/cyber-asset-attack-surface-management-caasm-tools/>

12 <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

13 <https://www.openappsec.io/post/best-cyber-asset-attack-surface-management-tools-for-2025>

14 <https://es-la.tenable.com/cybersecurity-guide/learn/what-is-caasm>

15 <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

16 <https://www.vectra.ai/topics/attack-surface-management>

17 <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

18 <https://www.crowdstrike.com/es-es/cybersecurity-101/exposure-management/cyber-asset-attack-surface-management-caasm/>

19 <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

20 <https://www.openappsec.io/post/best-cyber-asset-attack-surface-management-tools-for-2025>

21 <https://es-la.tenable.com/cybersecurity-guide/learn/what-is-caasm>

22 <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

23 <https://www.vectra.ai/topics/attack-surface-management>

24 <https://www.vectra.ai/topics/attack-surface-management>

- Porcentaje de activos descubiertos vs activos estimados (ratio de “oscuridad” de la superficie de ataque).
- Proporción de TI invisible / “shadow IT” detectada (activos no inventariados que aparecen en escaneos CAASM).
- Cobertura de activos por dominio: TI tradicional, OT, IoT, nube (IaaS/PaaS/SaaS), identidades, contenedores/Kubernetes, APIs e interfaces externas.¹³¹⁷²¹²³
- Grado de integración de fuentes (número y tipo de conectores activos: CMDB, EDR, IAM, nube, escáner de vulnerabilidades, SIEM, etc.).¹⁷²¹²³
- Actualidad de los datos: latencia media de actualización de inventario, porcentaje de activos con datos “stale”.⁷²³¹

2.2. Higiene de seguridad y controles

Alineado con la capa de validación de controles que describen Tenable y otros fabricantes:²⁵²⁶²⁷²⁸²⁹

- Porcentaje de activos protegidos por EDR/XDR, cifrado, gestión de parches, MFA y microsegmentación declarados y realmente aplicados (validado por CAASM).
- Densidad de activos con configuraciones inseguras (puertos expuestos, servicios inseguros, cifrados débiles, identidades sin MFA, etc.).²¹³³⁷
- Cobertura de políticas Zero Trust a nivel de activos: porcentaje de activos integrados en políticas de acceso basado en identidad y contexto.¹⁴¹²³
- Número de brechas de control por activo crítico (activos marcados como críticos sin todos los controles exigidos por el marco interno o normas como NIS2/ENS).

2.3. Exposición y riesgo material

Las guías recientes enfatizan que CAASM debe ir más allá del CVSS bruto y acercarse a riesgo material, apoyándose en inteligencia de amenazas y modelos como EPSS.³⁰³¹³²³³³⁴³⁵

²⁵ <https://www.openappsec.io/post/best-cyber-asset-attack-surface-management-tools-for-2025>

²⁶ <https://www.vectra.ai/topics/attack-surface-management>

²⁷ <https://www.centraleyes.com/cyber-asset-attack-surface-management-caasm-tools/>

²⁸ <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

²⁹ <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

³⁰ <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

³¹ <https://www.centraleyes.com/cyber-asset-attack-surface-management-caasm-tools/>

³² <https://www.marketreportanalytics.com/reports/cyber-asset-attack-surface-management-52485>

- Activos con vulnerabilidades explotables (según EPSS, inteligencia de amenazas o explotación observada).³⁴⁷²
- “Toxic combinations”: activos donde convergen alta criticidad de negocio, exposición externa y vulnerabilidades o fallos de control de alto impacto.¹²¹³²³
- Superficie de ataque externa vs interna (número y criticidad de activos expuestos a Internet, terceros o redes interconectadas).⁶¹³³
- Riesgo agregado por dominio (TI, OT, nube, identidades, APIs) ponderado por impacto de negocio, en línea con la priorización recomendada por ASM/CAASM.¹³¹²¹²³

2.4. Remediación y capacidad de respuesta

Las mejores prácticas de ASM subrayan que la métrica relevante ya no es “cuántas vulnerabilidades tengo”, sino “con qué cadencia y eficacia cierro las que importan”.³⁶³⁷³⁸³⁹

- MTTR de exposición (tiempo medio para mitigar exposición relevante, no solo aplicar parches).
- Porcentaje de exposiciones críticas cerradas dentro de los SLA internos (por ejemplo, 7 días para exposiciones de alto riesgo).
- Tasa de recurrencia: exposiciones críticas que reaparecen tras una remediación teórica (indica falta de control estructural).¹²¹³³
- Grado de automatización de remediación: porcentaje de exposiciones cerradas mediante flujos orquestados frente a tareas manuales.¹³³¹¹¹²

³³ <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

³⁴ <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

³⁵ <https://www.vectra.ai/topics/attack-surface-management>

³⁶ <https://socradar.io/wp-content/uploads/2025/12/Spain-Threat-Landscape-Report-2025.pdf>

³⁷ <https://www.centraleyes.com/cyber-asset-attack-surface-management-caasm-tools/>

³⁸ <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

³⁹ <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

2.5. Cumplimiento y reporting

Los proveedores apuntan a que CAASM se está integrando de forma nativa con marcos como NIST, ISO 27001, GDPR y las directivas europeas.⁴⁰⁴¹⁴²⁴³⁴⁴

- Trazabilidad de controles frente a marcos NIST SP 800-53, ISO 27001, NIS2, ENS, GDPR (porcentaje de controles con evidencias automáticas).
- Porcentaje de activos sin clasificación adecuada frente al marco de criticidad regulatoria (por ejemplo, esenciales e importantes NIS2).²³⁴
- Número de no conformidades detectadas a través de CAASM frente a auditorías puntuales (indicador de madurez de supervisión continua).³²¹²

3. Tendencias 2025+ en indicadores CAASM

Basándonos en informes y análisis recientes sobre ASM/CAASM y tendencias de amenazas en la UE, pueden identificarse varias “derivas” claras en las métricas.⁴⁵⁴⁶⁴⁷⁴⁸⁴⁹⁵⁰⁵¹⁵²

40 <https://www.marketreportanalytics.com/reports/cyber-asset-attack-surface-management-52485>

41 <https://www.crowdstrike.com/es-es/cybersecurity-101/exposure-management/cyber-asset-attack-surface-management-caasm/>

42 <https://www.vectra.ai/topics/attack-surface-management>

43 <https://www.kuppingercole.com/watch/attack-surface-management>

44 <https://www.centraleyes.com/cyber-asset-attack-surface-management-caasm-tools/>

45 <https://socradar.io/wp-content/uploads/2025/12/Spain-Threat-Landscape-Report-2025.pdf>

46 <https://www.jupiterone.com/blog/the-ultimate-caasm-guide-for-2025>

47 <https://www.vectra.ai/topics/attack-surface-management>

48 <https://www.centraleyes.com/cyber-asset-attack-surface-management-caasm-tools/>

49 <https://www.openappsec.io/post/best-cyber-asset-attack-surface-management-tools-for-2025>

50 <https://www.centraleyes.com/cyber-asset-attack-surface-management-caasm-tools/>

51 <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

52 <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

3.1. De inventario a riesgo de exposición continua

- La literatura de ASM reciente sitúa la gestión de superficie de ataque como ciclo continuo de descubrimiento, clasificación, priorización, remediación y monitorización, lo que empuja a medir ciclos más que fotos fijas.¹⁰¹¹³
- Los indicadores dejan de centrarse en “# vulnerabilidades” y pasan a “exposiciones materialmente explotables cerradas por unidad de tiempo”, en paralelo con el enfoque por riesgo de ENISA y el paisaje de amenazas de la UE (DDoS, ransomware, hacktivismo).⁴³
- Los informes de mercado señalan la maduración de CAASM como mercado propio, con previsiones de crecimiento significativo y consolidación en suites de gestión de exposición, lo que refuerza el énfasis en métricas de reducción de riesgo cuantificable y retorno de inversión.⁹⁵¹⁰¹¹¹²

3.2. Extensión de dominio: nube, IoT/OT, APIs, IA

- Los fabricantes resaltan la capacidad de CAASM para abarcar IoT, OT y dispositivos de borde, ampliando el espacio de métricas hacia indicadores sectoriales (por ejemplo, proporción de activos OT con segmentación adecuada, número de interfaces IT/OT expuestas).¹²¹²¹³³
- El énfasis en APIs y superficies cloud hace que los indicadores incluyan “número de endpoints de API expuestos por error”, “recursos cloud sin etiquetado de criticidad” o “identidades cloud con privilegios excesivos”, integrados en el inventario CAASM.¹¹¹¹²¹³³
- Los análisis de ASM empiezan a incorporar ataque a capas de IA y modelos, proponiendo métricas de exposición asociadas a servicios de IA, aunque aún de forma emergente.³

3.3. IA para priorización y predicción

- Los informes técnicos subrayan el uso creciente de IA y ML en CAASM para priorizar riesgos, correlacionando valor del activo, vulnerabilidades, exposición real y contexto de amenazas.⁷²¹²¹³³
- La utilización de modelos como EPSS y motores de predicción de explotación se refleja en métricas como “porcentaje de vulnerabilidades con alta probabilidad de explotación aún no mitigadas”.⁷²³
- Surgen indicadores de eficacia de la priorización, como “porcentaje de incidentes graves originados en exposiciones previamente clasificadas como bajas”, que sirven para recalibrar los modelos.¹²¹³³

3.4. Afinidad regulatoria europea (NIS2, ENS, CRA, DORA)

- El enfoque europeo en amenazas (ENISA) y NIS2 pone el acento en sectores esenciales y servicios críticos, lo que impulsa métricas por sector, exposición y criticidad de servicio.⁴
- España, inmersa en la aplicación de NIS2, ENS y otros marcos como GDPR y DORA, se ve empujada hacia indicadores de superficie de ataque que permitan demostrar supervisión continua en entidades esenciales e importantes.¹⁵⁶⁴
- CAASM se posiciona como fuente de evidencia para auditorías y autoridades, fomentando métricas de “grado de cobertura de controles ENS/NIS2 por activo” y “tiempo de detección de desviaciones de configuración exigidas por normativa”.²¹²³⁴

4. Propuesta de cuadro de mando CAASM nacional para España

A partir de la literatura de CAASM, las tendencias ASM y los informes de amenazas a nivel UE y España, puede bosquejarse un cuadro de indicadores a nivel país, con vocación comparativa internacional.

4.1. Ejes principales de medición

- 1) **Visibilidad y exactitud del inventario nacional**
- 2) **Exposición de superficie de ataque en sectores esenciales y estratégicos**
- 3) **Capacidad de remediación y resiliencia**
- 4) **Convergencia con marcos regulatorios europeos**
- 5) **Madurez de gobernanza y cooperación público-privada**

4.2. Indicadores sugeridos (vista de alto nivel)

Tabla de categorías y ejemplos de indicadores para un Observatorio Nacional de CAASM:

53 <https://es-la.tenable.com/cybersecurity-guide/learn/what-is-caasm>

54 <https://www.vectra.ai/topics/attack-surface-management>

55 <https://www.jupiterone.com/blog/the-ultimate-caasm-guide-for-2025>

56 <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

57 <https://www.tenable.com/cybersecurity-guide/learn/what-is-caasm>

58 <https://www.vectra.ai/topics/attack-surface-management>

59 <https://www.centraleyes.com/cyber-asset-attack-surface-management-caasm-tools/>

60 <https://industrialcyber.co/reports/enisa-2025-threat-landscape-report-highlights-eu-faces-escalating-hackivist-attacks-and-state-aligned-cyber-threats/>

61 <https://www.marketreportanalytics.com/reports/cyber-asset-attack-surface-management-52485>

Dimensión	Indicador sugerido (nivel país)
Visibilidad	Porcentaje estimado de activos críticos (TI/OT/IoT/nube) con representación en plataformas CAASM u homólogas en entidades esenciales.17234
Visibilidad	Ratio medio de activos “descubiertos pero no inventariados” en entidades reguladas (shadow IT) por sector.17234
Exposición	Número y proporción de servicios expuestos a Internet en sectores esenciales sin controles mínimos (MFA, cifrado robusto, endurecimiento básico).72346
Exposición	Densidad de activos OT e IoT sin segmentación adecuada en infraestructuras críticas.121234
Riesgo	Porcentaje de exposiciones con alta probabilidad de explotación (EPSS u otros) pendientes de mitigación en entidades esenciales.7234
Riesgo	Tasa de incidentes significativos asociados a exposiciones previamente identificadas en ASM/CAASM (indicador de brecha entre conocimiento y acción).346
Remediación	MTTR medio de exposición crítica en sectores esenciales (días) y desviación estándar entre sectores.1213346
Remediación	Porcentaje de exposiciones críticas cerradas dentro de plazos recomendados por NIS2 / ENS (por ejemplo, $\leq 7/30$ días según criticidad).234
Cumplimiento	Cobertura media de controles ENS/NIS2 (seguridad de redes, gestión de activos, gestión de vulnerabilidades) evidenciada automáticamente mediante CAASM.23415
Cumplimiento	Número de no conformidades recurrentes detectadas en auditorías vs exposiciones ya señaladas por CAASM (indicador de inacción).21234
Gobernanza	Porcentaje de entidades esenciales que comparten telemetría de superficie de ataque con el CSIRT nacional de forma periódica.4156
Gobernanza	Existencia y uso de un repositorio nacional de “patrones de exposición” (misconfiguraciones recurrentes, top errores cloud, etc.).34156

La gracia literaria, por si la quieres enunciada, sería pasar de la métrica “número de servidores” a la métrica “número de oportunidades objetivas que tiene un adversario mínimamente capaz de arruinarnos el café del lunes”.

5. España en contexto internacional: puntos finos

A partir del paisaje europeo de amenazas y del peso regulatorio, la construcción de indicadores CAASM a nivel nacional en España debería dialogar con las siguientes realidades.⁶²⁶³⁶⁴⁶⁵⁶⁶

5.1. Presión de amenaza y sectores prioritarios

- ENISA destaca que en la UE los DDoS de hacktivismo y el ransomware siguen siendo amenazas dominantes, con especial impacto en administraciones públicas y sectores esenciales recogidos en NIS2.⁴
- Informes sobre España subrayan el papel de servicios de información, seguridad nacional y otros sectores clave, indicando una concentración de ataques en ámbitos ya señalados por la regulación.⁶
- Este patrón empuja a que las métricas CAASM nacionales prioricen exposición de superficie de ataque en administración pública, operadores críticos, servicios digitales esenciales y cadena de suministro.¹⁵⁶⁴

5.2. Regulación y mercado nacional

- El ecosistema español vive un incremento de presión normativa por GDPR, NIS2, DORA, ENS y el futuro Reglamento de Ciberresiliencia, con exigencias crecientes de evidencias continuas, no solo auditorías anuales.¹⁵⁴
- El mercado de ciberseguridad en España muestra crecimiento de doble dígito, impulsado por migración a la nube, arquitecturas API-first y adopción de Zero Trust, lo que amplía la superficie y refuerza la necesidad de CAASM como soporte a estos modelos.¹⁵
- A nivel internacional, otros países (p.ej., Canadá) publican evaluaciones de amenazas nacionales que podrían beneficiarse de indicadores CAASM similares, lo que permite diseñar métricas comparables y “exportables”.¹⁰¹⁶⁴

5.3. Oportunidad de liderazgo metodológico

- La UE ya dispone de marcos de referencia de amenazas y sectores esenciales, por lo que España podría elaborar un “apéndice CAASM” nacional que defina indicadores mínimos homogéneos por sector y tamaño de entidad.⁶⁴
- Esta estandarización facilitaría comparaciones internacionales con otros miembros UE y con países con informes nacionales de amenazas, siempre que adopten indicadores similares de exposición, tiempo de remediación y cobertura de controles.¹⁶¹⁰⁴

⁶² <https://www.openappsec.io/post/best-cyber-asset-attack-surface-management-tools-for-2025>

⁶³ <https://www.zscaler.com/es/products-and-solutions/caasm>

⁶⁴ <https://www.vectra.ai/topics/attack-surface-management>

⁶⁵ <https://deepstrike.io/blog/top-cybersecurity-companies-spain>

⁶⁶ <https://www.cyber.gc.ca/en/guidance/national-cyber-threat-assessment-2025-2026>

6. Batería de preguntas de encuesta (tono inquisitivo-constructivo)

A continuación, una lista de preguntas y posibles respuestas tipo Likert / opción múltiple para un cuestionario dirigido a CISOs, responsables de riesgo o arquitectos de seguridad en España, con enfoque CAASM nacional y comparativo.

6.1. Visibilidad de activos

1. “En su organización, ¿qué grado de confianza tiene en que el inventario de activos refleja la realidad viva de su superficie de ataque (TI, OT, IoT, nube, identidades, APIs)?”

Casi total: confiamos en datos consolidados por una plataforma de CAASM.

Alta: disponemos de varias fuentes integradas, aunque aún hay islas.

Limitada: sabemos que hay “zonas oscuras”, especialmente en nube y OT.

Francamente baja: sospechamos que el mapa es más un deseo que una topografía.

2. “¿Con qué frecuencia se detectan activos ‘sorpresa’ (no inventariados) en auditorías, pentests o escaneos externos?”

Rara vez (menos de una vez al año).

Ocasionalmente (1–2 veces al año).

Con frecuencia (trimestralmente).

Siempre que alguien mira con un poco de mala intención.

- Casi total: confiamos en datos consolidados por una plataforma de CAASM.
- Alta: disponemos de varias fuentes integradas, aunque aún hay islas.
- Limitada: sabemos que hay “zonas oscuras”, especialmente en nube y OT.
- Francamente baja: sospechamos que el mapa es más un deseo que una topografía.
- Rara vez (menos de una vez al año).
- Ocasionalmente (1–2 veces al año).
- Con frecuencia (trimestralmente).
- Siempre que alguien mira con un poco de mala intención.

6.2. Cobertura de controles y Zero Trust

3. “¿Qué porcentaje aproximado de sus activos críticos cuenta con todos los controles de seguridad definidos (EDR/XDR, cifrado, parches al día, MFA, segmentación adecuada)?”
 - ≥ 90% (lo que falta está en un plan de retirada digna).
 - Entre 70% y 89% (las brechas están identificadas y priorizadas).
 - Entre 40% y 69% (sabemos qué falta, pero falta oxígeno y presupuesto).
 - < 40% (nuestra estrategia es la fe y algún que otro firewall heroico).

 4. “Respecto a la adopción de un modelo Zero Trust apoyado en CAASM (inventario de identidades, dispositivos, servicios y datos), su organización se encuentra...”
 - En fase avanzada: políticas dinámicas basadas en contexto y riesgo de activo.
 - En despliegue: pilotos activos en varios dominios (nube, VPN, entornos sensibles).
 - En planificación: hay estrategia y hojas de ruta, aún sin despliegue significativo.
 - En fase de contemplación filosófica: hablamos mucho de Zero Trust en presentaciones.
-
- ≥ 90% (lo que falta está en un plan de retirada digna).
 - Entre 70% y 89% (las brechas están identificadas y priorizadas).
 - Entre 40% y 69% (sabemos qué falta, pero falta oxígeno y presupuesto).
 - < 40% (nuestra estrategia es la fe y algún que otro firewall heroico).
 - En fase avanzada: políticas dinámicas basadas en contexto y riesgo de activo.
 - En despliegue: pilotos activos en varios dominios (nube, VPN, entornos sensibles).
 - En planificación: hay estrategia y hojas de ruta, aún sin despliegue significativo.
 - En fase de contemplación filosófica: hablamos mucho de Zero Trust en presentaciones.

6.3. Exposición y riesgo material

5. “En los últimos 12 meses, ¿se han materializado incidentes significativos vinculados a activos o servicios que CAASM / ASM ya había señalado como ‘en riesgo’?”

No, las exposiciones identificadas se han tratado a tiempo.

Sí, pero fueron contenidos sin impacto material relevante.

Sí, con impacto operativo o reputacional apreciable.

Sí, y seguimos revisando el diccionario de la palabra ‘prioridad’.

6. “En términos de priorización del riesgo técnico, ¿qué peso real tiene hoy la probabilidad de explotación (EPSS, inteligencia de amenazas) frente a la mera severidad de vulnerabilidades (CVSS)?”

Predomina la probabilidad de explotación y el contexto de negocio.

Intentamos ponderar ambos, aunque CVSS sigue dominando las discusiones.

La severidad técnica es el criterio de facto (CVSS como evangelio).

El criterio dominante es ‘lo que podemos apagar sin protestas de negocio’.

- No, las exposiciones identificadas se han tratado a tiempo.
- Sí, pero fueron contenidos sin impacto material relevante.
- Sí, con impacto operativo o reputacional apreciable.
- Sí, y seguimos revisando el diccionario de la palabra ‘prioridad’.
- Predomina la probabilidad de explotación y el contexto de negocio.
- Intentamos ponderar ambos, aunque CVSS sigue dominando las discusiones.
- La severidad técnica es el criterio de facto (CVSS como evangelio).
- El criterio dominante es ‘lo que podemos apagar sin protestas de negocio’.

6.4. Remediación y ciclo de vida

7. “¿Cuál es su tiempo medio de mitigación de exposiciones críticas (no solo parcheo, sino cierre efectivo de la ventana de ataque)?”

Menos de 7 días.

Entre 7 y 30 días.

Entre 1 y 3 meses.

Más de 3 meses, o indeterminado (las exposiciones adquieren ciudadanía permanente).

8. “¿Qué grado de automatización existe en la remediación de exposiciones identificadas por CAASM?”

Alto: uso extensivo de flujos automatizados (SOAR / playbooks).

Moderado: automatización para casos conocidos, manual para el resto.

Bajo: la mayoría de las remediaciones requieren coordinación manual.

Nulo: CAASM nos informa y nosotros suspiramos.

- Menos de 7 días.
- Entre 7 y 30 días.
- Entre 1 y 3 meses.
- Más de 3 meses, o indeterminado (las exposiciones adquieren ciudadanía permanente).
- Alto: uso extensivo de flujos automatizados (SOAR / playbooks).
- Moderado: automatización para casos conocidos, manual para el resto.
- Bajo: la mayoría de las remediaciones requieren coordinación manual.
- Nulo: CAASM nos informa y nosotros suspiramos.

6.5. Cumplimiento y entorno regulatorio

9. “¿Hasta qué punto utiliza su organización CAASM o herramientas equivalentes para obtener evidencias continuas de cumplimiento (ENS, NIS2, GDPR, DORA)?”

Es la fuente principal de evidencias y reporting continuo.

Se usa como complemento a auditorías tradicionales y revisiones manuales.

Se utiliza de forma parcial, en algunos dominios (p. ej., nube o endpoints).

No lo usamos para cumplimiento, solo para apagar incendios técnicos.

10. “De cara a NIS2 y ENS, ¿qué nivel de preparación percibe a la luz de las métricas de superficie de ataque (exposición de servicios, activos críticos inventariados, tiempos de remediación)?”

Alto: métricas consolidadas, brechas identificadas y proyectos en marcha.

Medio: buena visibilidad, pero brechas relevantes aún sin financiación asegurada.

Bajo: sabemos que el delta entre regulación y realidad es considerable.

Experimental: aún estamos intentando decidir qué debe medirse exactamente.

- Es la fuente principal de evidencias y reporting continuo.
- Se usa como complemento a auditorías tradicionales y revisiones manuales.
- Se utiliza de forma parcial, en algunos dominios (p. ej., nube o endpoints).
- No lo usamos para cumplimiento, solo para apagar incendios técnicos.
- Alto: métricas consolidadas, brechas identificadas y proyectos en marcha.
- Medio: buena visibilidad, pero brechas relevantes aún sin financiación asegurada.
- Bajo: sabemos que el delta entre regulación y realidad es considerable.
- Experimental: aún estamos intentando decidir qué debe medirse exactamente.

¿Te interesa que bajemos del Olimpo conceptual al barro sectorial (por ejemplo, indicadores CAASM específicos para sanidad, energía o administración pública en España)?

1718192021222324252627282930